

# Information Security Policy

Comprehensive Security Framework for Systems, Data, and Personnel

IT Security & Compliance Department

Document ID: TVSC-SEC-001 | Version 2.5 | Classification: Internal

## 1. Purpose and Scope

This policy establishes the information security requirements for all personnel who access TechViet systems, networks, or data — including full-time employees, part-time staff, contractors, interns, and third-party vendors. It covers all TechViet-owned and managed information assets regardless of location: office premises, remote work environments, client sites, and cloud infrastructure. Compliance with this policy is mandatory and is audited quarterly by the internal security team and annually by an external auditor (currently Deloitte Vietnam).

This policy is aligned with ISO 27001:2022, the Vietnam Cybersecurity Law (2018), and the CIS Controls v8 framework. TechViet achieved ISO 27001 certification in March 2024 and maintains SOC 2 Type II compliance for client-facing services.

## 2. Data Classification Framework

All data created, processed, stored, or transmitted by TechViet must be classified by the data owner according to the following framework. Misclassification or failure to classify is a policy violation. When in doubt, apply the higher classification level.

| Level | Label        | Examples                                                                       | Storage                                                | Sharing                                               | Disposal                                                       |
|-------|--------------|--------------------------------------------------------------------------------|--------------------------------------------------------|-------------------------------------------------------|----------------------------------------------------------------|
| C4    | Top Secret   | Encryption keys, pen-test results, M&A; plans, executive financial models      | Hardware-encrypted vault; dedicated server             | Need-to-know; CISO approval; no copies                | Cryptographic erasure; physical destruction for media          |
| C3    | Confidential | Client source code, PII, salary data, financial reports, security configs      | Encrypted at rest (AES-256) and in transit (TLS 1.3)   | VP approval required; encrypted transfer only; logged | Secure deletion (3-pass overwrite); certificate of destruction |
| C2    | Internal     | Internal emails, project plans, meeting notes, architecture docs, Jira tickets | Standard access controls; company-managed storage only | Internal only; do not forward to personal email       | Standard deletion; no special procedures                       |
| C1    | Public       | Marketing materials, blog posts, open-source contributions, job postings       | No restrictions                                        | May be shared freely                                  | No restrictions                                                |

## 3. Access Control

### 3.1 Authentication Standards

TechViet enforces a defense-in-depth approach to authentication. All systems accessible from the internet require multi-factor authentication (MFA). Single sign-on (SSO) via Google Workspace SAML is the standard authentication method for all SaaS applications.

| Requirement             | Standard      | Enforcement Mechanism                                       |
|-------------------------|---------------|-------------------------------------------------------------|
| Minimum Password Length | 14 characters | Okta password policy; rejects shorter passwords at creation |

| Requirement         | Standard                                                                                      | Enforcement Mechanism                                                       |
|---------------------|-----------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------|
| Password Complexity | Must include: uppercase, lowercase, digit, and special character (!@#\$%^&*)                  | Okta policy; real-time feedback during password creation                    |
| Password Rotation   | Every 90 days; last 12 passwords cannot be reused                                             | Okta policy; automated expiry notification at 14, 7, and 1 day(s)           |
| Account Lockout     | Locked after 5 consecutive failed attempts                                                    | Auto-unlock after 30 min; IT can manually unlock with identity verification |
| MFA Method          | Primary: Hardware key (YubiKey 5).<br>Fallback: TOTP authenticator app (Google/Authy)         | Okta MFA policy; SMS and phone call MFA are explicitly disabled             |
| Session Timeout     | Web applications: 8 hours idle. VPN: 12 hours idle. Admin consoles: 30 min idle.              | Application-level config; enforced via Okta session policies                |
| Service Accounts    | No interactive login. API key rotation every 30 days. Scoped to minimum required permissions. | Vault-managed secrets; automated rotation via HashiCorp Vault               |

### 3.2 Role-Based Access Control (RBAC)

Access to systems and data is granted based on the principle of least privilege. Access rights are tied to job roles, not individuals. When an employee changes roles, their access is reviewed and adjusted within 2 business days. Quarterly access reviews are conducted by each department head.

| Role              | Systems Access                                                                        | Data Classification Access          | Approval Required                 | Review Cycle         |
|-------------------|---------------------------------------------------------------------------------------|-------------------------------------|-----------------------------------|----------------------|
| Standard Employee | Email, Slack, Google Drive, Confluence, HR Portal                                     | C1, C2 only                         | Auto-provisioned at onboarding    | Annual               |
| Developer         | Above + GitHub, Jira, staging environments, CI/CD, Sentry                             | C1, C2, C3 (own project scope only) | Team Lead approval                | Quarterly            |
| DevOps/SRE        | Above + AWS Console, Terraform Cloud, ArgoCD, production monitoring (read-only)       | C1, C2, C3                          | Engineering Manager + IT Security | Monthly              |
| Database Admin    | Above + production database access (write), backup systems, Vault admin               | C1, C2, C3, C4                      | CTO approval                      | Monthly              |
| Security Team     | All systems including SIEM, WAF, vulnerability scanners, forensics tools              | All classifications                 | CISO approval                     | Monthly              |
| Executive         | Business analytics, financial systems, board materials, all Confluence spaces         | C1, C2, C3, C4 (business scope)     | Auto-provisioned per role         | Quarterly            |
| Contractor        | Scoped to specific project. No access to internal HR, finance, or other project data. | C1, C2, C3 (project scope only)     | Project Manager + IT Security     | Per contract renewal |

## 4. Network Security

All TechViet office networks are segmented into isolated zones to contain potential breaches. Inter-zone traffic is filtered by next-generation firewalls (Palo Alto PA-3260 series). All outbound web traffic is inspected by Zscaler Internet Access (ZIA) for malware, DLP, and unauthorized data exfiltration. DNS resolution uses Cloudflare Gateway with threat intelligence feeds enabled.

| Network Zone               | Purpose                                                     | Access Policy                                                             | Monitoring                                             |
|----------------------------|-------------------------------------------------------------|---------------------------------------------------------------------------|--------------------------------------------------------|
| Corporate LAN (VLAN 10)    | Employee workstations, printers, meeting room equipment     | NAC (802.1X); domain-joined devices only                                  | Datadog Network Monitoring; 90-day NetFlow retention   |
| Development VLAN (VLAN 20) | Dev servers, container hosts, build agents                  | Developer role required; MFA for SSH access                               | Full packet capture retained 7 days; flow data 90 days |
| Server DMZ (VLAN 30)       | Production-facing services, load balancers, reverse proxies | IP whitelist + WAF (Cloudflare); no direct internet egress                | 24/7 SOC monitoring; all traffic logged to SIEM        |
| Guest Wi-Fi (VLAN 99)      | Visitors, personal devices                                  | Internet only; completely isolated from corporate network; captive portal | Basic logging; 30-day retention                        |
| Management VLAN (VLAN 5)   | Network equipment, IPMI/iDRAC, security appliances          | IT Security team only; hardware MFA + VPN required                        | All access logged; alerts on any unauthorized attempt  |

## 5. Endpoint Security

| Control                  | Requirement                                                                                                      | Enforcement                                                      | Compliance Check                                                             |
|--------------------------|------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------|------------------------------------------------------------------------------|
| Endpoint Detection (EDR) | CrowdStrike Falcon on all endpoints. Real-time protection enabled. Cannot be disabled by user.                   | Jamf (macOS) / Intune (Windows); auto-remediation if agent stops | Daily compliance scan; non-compliant devices lose network access in 24 hours |
| Disk Encryption          | FileVault 2 (macOS) or BitLocker (Windows) with AES-256. Recovery keys escrowed in Jamf/Intune.                  | MDM-enforced at enrollment; cannot be deferred                   | Weekly audit; HR notified for persistent non-compliance                      |
| OS Patching              | Critical/high CVEs: within 72 hours. Medium: within 14 days. Low: next maintenance window.                       | WSUS (Windows) / Jamf (macOS); staged rollout with 10% canary    | Weekly compliance dashboard; monthly report to CISO                          |
| Screen Lock              | Auto-lock after 5 minutes of inactivity. Lock on lid close.                                                      | MDM policy; user cannot override timeout                         | Enforced at MDM level; verified during quarterly audits                      |
| USB/External Devices     | Blocked by default. Exceptions require IT Security ticket with business justification. Approved for max 30 days. | CrowdStrike Device Control; whitelist by serial number           | Monthly audit of active exceptions                                           |
| Browser Extensions       | Only approved extensions from TechViet Software Center. Unapproved extensions auto-removed within 24 hours.      | Chrome Enterprise policy via Google Admin                        | Weekly scan; report to IT Security                                           |

## 6. Incident Response Framework

All security incidents must be reported to the Security Operations Center (SOC) within 1 hour of discovery. Reporting channels: #security-incidents on Slack (preferred), email to soc@techviet.vn, or phone extension 911 (after hours). The SOC operates 24/7 with a team of 4 analysts across 2 shifts.

| Severity      | Definition                                                                  | Examples                                                                                                       | Response SLA                               | Escalation Path                                                            |
|---------------|-----------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------|--------------------------------------------|----------------------------------------------------------------------------|
| P1 — Critical | Active breach, data exfiltration, or complete service compromise            | Ransomware infection, confirmed data breach, compromised admin credentials                                     | 15 minutes to triage; 1 hour to contain    | CISO + CEO within 30 min; Legal within 1 hour; external IR firm on standby |
| P2 — High     | Suspected breach, active exploitation attempt, or significant vulnerability | Malware detected on endpoints, unauthorized access to C3+ data, zero-day in production stack                   | 1 hour to triage; 4 hours to contain       | CISO within 2 hours; affected team leads immediately                       |
| P3 — Medium   | Policy violation, phishing attempt, or low-impact vulnerability             | Employee clicked phishing link (no credentials entered), unpatched non-critical system, minor policy deviation | 4 hours to triage; 24 hours to remediate   | Security Manager next business day                                         |
| P4 — Low      | False positive, informational finding, or minor anomaly                     | Legitimate software flagged by EDR, benign port scan from known scanner, cosmetic security header missing      | 24 hours to triage; best-effort resolution | SOC Analyst; no escalation required                                        |

## 7. Data Backup and Disaster Recovery

| System / Data                     | Backup Strategy                                                | Frequency                       | Retention                         | RTO       | RPO           | Test Frequency           |
|-----------------------------------|----------------------------------------------------------------|---------------------------------|-----------------------------------|-----------|---------------|--------------------------|
| Production Databases (PostgreSQL) | Continuous WAL archiving + daily pg_dump                       | WAL: real-time; Full: daily 2AM | 90 days (daily); 1 year (monthly) | < 1 hour  | < 5 min       | Monthly restore drill    |
| Source Code (GitHub Enterprise)   | Real-time replication to secondary AWS region (ap-southeast-3) | Real-time                       | Indefinite (Git history)          | < 15 min  | 0 (real-time) | Quarterly failover test  |
| Google Workspace (Email/Drive)    | Daily incremental via Veeam Backup for Google                  | Daily at 1AM                    | 1 year                            | < 4 hours | < 24 hours    | Quarterly restore test   |
| Kubernetes Configs & Secrets      | Velero backup to S3; Vault auto-backup                         | Every 6 hours                   | 180 days                          | < 30 min  | < 6 hours     | Monthly restore drill    |
| CI/CD Pipelines (GitHub Actions)  | Infrastructure-as-Code in Git; secrets in Vault                | Real-time (Git)                 | Indefinite                        | < 30 min  | 0 (Git)       | After every infra change |
| Monitoring Data (Datadog)         | N/A (SaaS retention)                                           | Continuous                      | 15 months (Datadog plan)          | N/A       | N/A           | N/A                      |

Disaster recovery procedures are documented in the TechViet Business Continuity Plan (TVSC-BCP-001). The DR site is AWS ap-southeast-3 (Jakarta). Full DR drills are conducted semi-annually, with the last successful drill completed on November 14, 2025 (RTO achieved: 47 minutes, target: 60 minutes).